Propuesta de Gobernanza y Seguridad de la Información — INTERAFAS

Sistema de Gestión de Seguridad de la Información basado en ISO/IEC 27001:2022

@Luis · Oct 15, 2026

PR02	
Alumno	Luis Emmanuel Aronia Silva
Actividad	03. Propuesta de Gobernanza ISO/IEC 27001 (PR02-11 a PR02-20)
Materia	CNOIV Programación WAP
Maestro	Servando López Contreras

Sección 01 — Alcance

1.1 Presentación del proyecto a la Alta Dirección

Se presenta a la Alta Dirección de **INTERAFAS** el proyecto de implementación de un Sistema de Gestión de Seguridad de la Información (SGSI) con base en la norma **ISO/IEC 27001:2022**. El proyecto se ejecutará bajo la **Dirección de Tecnologías de la Información y Operaciones**, dentro del **área de Ciberseguridad y Gobierno de TI**, y abarcará los procesos de desarrollo y mantenimiento del portal web institucional, las APIs de servicios ciudadanos, la gestión de facturación y proveedores, y la red de Tecnología Operacional (OT) que soporta la infraestructura crítica.

Este proyecto nace directamente de los hallazgos documentados en el **Informe de Seguridad Ofensiva PR02-01 a PR02-10**, donde se identificaron 20 vulnerabilidades técnicas (configuraciones inseguras, IDOR, inyección SQL, XSS almacenado, fijación de sesión, control de acceso roto en API OT, entre otras) que evidencian la ausencia de un marco formal de gobernanza de seguridad de la información.

1.2 Fase 1 — Investigación y contextualización integral de INTERAFAS

1.2.1 Historia institucional

INTERAFAS (Infraestructura y Enlace de Agua, Fluidos y Servicios) se constituyó como organismo operador de infraestructura crítica hace poco más de veinticinco años, inicialmente como una dependencia administrativa pequeña encargada de la distribución de agua potable en la zona metropolitana. En su primera década operó exclusivamente con procesos manuales: lecturas de medidor en campo, facturación en papel y atención presencial en ventanilla. La segunda etapa de crecimiento, hace aproximadamente doce años, trajo la incorporación de energía y servicios municipales asociados a su mandato, consolidando a INTERAFAS como operador de infraestructura crítica multiservicio. En los últimos cinco años la organización emprendió una transformación digital acelerada:

portal web institucional, APIs de autoservicio para ciudadanos, un Centro de Operaciones con supervisión de planta vía SCADA/telemetría, un padrón electrónico de proveedores y un sistema de facturación y pagos en línea. Esta modernización, impulsada por presión presupuestal y por la exigencia ciudadana de servicios digitales, se ejecutó sin que la gobernanza de seguridad de la información creciera al mismo ritmo — la causa raíz identificada tanto en el Informe de Seguridad Ofensiva como en este proyecto.

1.2.2 Misión

Proveer y administrar de forma confiable los servicios de infraestructura crítica (agua, energía y servicios municipales asociados) de la zona metropolitana que atiende, garantizando continuidad operativa, transparencia y atención ciudadana de calidad, bajo principios de eficiencia, legalidad y responsabilidad social.

1.2.3 Visión

Ser reconocida, en un horizonte de cinco años, como una organización de infraestructura crítica modelo en la región por su madurez en gobernanza, ciberseguridad y transparencia institucional hacia la ciudadanía, sus proveedores y sus autoridades reguladoras, certificada bajo estándares internacionales como ISO/IEC 27001.

1.2.4 Valores institucionales

- **Confiabilidad.** La ciudadanía depende de la continuidad del servicio las 24 horas del día.
- **Transparencia.** Rendición de cuentas abierta sobre el uso de recursos públicos y el manejo de la información.
- **Legalidad.** Apego estricto al marco jurídico aplicable en materia de datos, contrataciones y servicios públicos.
- **Mejora continua.** Disposición institucional a aprender de auditorías, incidentes y hallazgos para fortalecer procesos.
- **Responsabilidad social y ambiental.** Gestión sostenible de los recursos que administra (agua, energía).

1.2.5 Objetivos estratégicos institucionales

1. Garantizar la continuidad y disponibilidad de los servicios operacionales críticos (agua, energía) ante fallas técnicas, desastres naturales o incidentes de seguridad.
2. Mantener la confianza ciudadana mediante el manejo responsable de datos personales y financieros.
3. Fortalecer la relación con proveedores y contratistas bajo principios de transparencia e integridad contractual.
4. Cumplir con el marco legal de protección de datos y con estándares internacionales de seguridad de la información (ISO/IEC 27001).
5. Modernizar la infraestructura tecnológica sin sacrificar la seguridad de la información ni la resiliencia operativa.
6. Profesionalizar al personal técnico y operativo en materia de ciberseguridad y gobernanza de TI.
7. Reducir el tiempo de detección y respuesta ante incidentes de seguridad a menos de 24 horas en un plazo de dos años.

1.2.6 Estructura organizacional y personal

```
Dirección General (1 titular + 2 asesores)
 ├── Dirección de Operaciones (Centro de Operaciones / OT - SCADA) — ~45 personas
 │    ├── Jefatura de Monitoreo de Planta (turnos 24/7)
 │    └── Jefatura de Mantenimiento de Infraestructura Física
 ├── Dirección de Tecnologías de la Información y Operaciones — ~28 personas
 │    ├── Área de Desarrollo y Plataformas Web (8 personas)
 │    ├── Área de Infraestructura y Redes (7 personas)
 │    └── Área de Ciberseguridad y Gobierno de TI (4 personas — responsable del SGSI)
 ├── Dirección de Atención Ciudadana y Comunicación Social — ~20 personas
 │    ├── Centro de Atención Telefónica y Ventanillas
 │    └── Jefatura de Comunicación Social y Vocería
 ├── Dirección Jurídica y Cumplimiento — ~9 personas
 ├── Dirección Administrativa y de Proveedores — ~15 personas
 │    ├── Jefatura de Contrataciones y Padrón de Proveedores
 │    └── Jefatura de Facturación y Cobranza
 └── Dirección de Recursos Humanos — ~10 personas
```

En total, INTERAFAS emplea aproximadamente 130 personas. El Área de Ciberseguridad y Gobierno de TI, con apenas cuatro integrantes, es desproporcionadamente pequeña frente al tamaño del parque tecnológico que debe proteger — un hallazgo que la Alta Dirección debe considerar al aprobar los recursos del SGSI (Cláusula 7.1).

1.2.7 Servicios que presta INTERAFAS

- Suministro y distribución de agua potable y drenaje.
- Suministro de energía para infraestructura municipal asociada.
- Facturación, cobranza y atención de aclaraciones a usuarios.
- Gestión del padrón de proveedores y contrataciones públicas.
- Atención ciudadana (reportes de fallas, solicitudes, trámites) por portal web y ventanilla.
- Transparencia institucional y rendición de cuentas (documentos públicos, contratos).

1.2.8 Cultura organizacional y tradiciones internas

INTERAFAS mantiene una cultura fuertemente orientada a la continuidad del servicio ("el agua y la energía no pueden detenerse"), lo que históricamente ha priorizado la disponibilidad por encima de otros atributos de seguridad de la información, incluyendo la confidencialidad e integridad. Entre las prácticas y tradiciones institucionales identificadas en la investigación destacan: la "Semana de la Infraestructura Crítica" (jornada anual de puertas abiertas y concientización ciudadana), el reconocimiento interno al "Equipo del Trimestre" en el Centro de Operaciones, y un fuerte sentido de antigüedad y lealtad entre el personal operativo, muchos de ellos con más de 15 años en la organización. Esta misma antigüedad explica parte de la resistencia cultural al cambio hacia prácticas de desarrollo seguro y gobierno de TI modernas, un factor de contexto interno relevante para el diseño de las políticas funcionales (Sección 05) y del soporte de prevención (Sección 07).

1.2.9 Panorama tecnológico (insumo técnico, basado en INTERAFAS-LAB)

El ecosistema tecnológico de INTERAFAS comprende: un portal web institucional con APIs REST de autoservicio, una base de datos relacional central, un sistema de facturación y pagos integrado a una pasarela SPEI, un padrón de proveedores y contrataciones, un sistema de atención y reportes

ciudadanos, y una red de Tecnología Operacional (OT) con interfaz HMI y telemetría de planta. Este panorama, documentado técnicamente durante la auditoría ofensiva (INTERAFAS-LAB), es la base objetiva sobre la que se construyen los activos de información de la Sección 04.

1.3 Presentación del proyecto a la Alta Dirección

Con base en la investigación anterior, se presenta a la Alta Dirección de **INTERAFAS** el proyecto de implementación de un Sistema de Gestión de Seguridad de la Información (SGSI) con base en la norma **ISO/IEC 27001:2022**. El proyecto se ejecutará bajo la **Dirección de Tecnologías de la Información y Operaciones**, dentro del **Área de Ciberseguridad y Gobierno de TI**, y abarcará los procesos de desarrollo y mantenimiento del portal web institucional, las APIs de servicios ciudadanos, la gestión de facturación y proveedores, y la red de Tecnología Operacional (OT) que soporta la infraestructura crítica.

1.4 Alcance del SGSI

El SGSI cubre: el portal web institucional y sus APIs públicas, los sistemas de facturación y pagos, el padrón de proveedores y contrataciones, los procesos de atención ciudadana (reportes), la gestión de sesiones y credenciales, y la interfaz de supervisión de la red operacional (OT/telemetría), incluyendo la información de identificación personal (PII) y financiera que estos procesos tratan. Quedan fuera del alcance inicial los sistemas de control físico de actuadores (PLC/RTU) a nivel de campo, que se abordarán en una fase posterior del programa de ciberseguridad OT.

Sección 02 — Referencias normativas

2.1 Estándares de la familia ISO/IEC 27000 de interés para INTERAFAS

Norma	Título	Relevancia para INTERAFAS
ISO/IEC 27000	SGSI — Visión general y vocabulario	Define los términos base usados en este documento (ver Sección 03).
ISO/IEC 27001:2022	SGSI — Requisitos	Norma rectora de este proyecto; establece los requisitos de Cláusulas 4–10.
ISO/IEC 27002:2022	Controles de seguridad de la información	Guía de implementación de los 93 controles del Anexo A (Sección 05).
ISO/IEC 27003	Guía de implementación del SGSI	Orientación práctica para el despliegue del proyecto.
ISO/IEC 27004	Seguimiento, medición, análisis y evaluación	Base metodológica de la Sección 09 (evaluación del desempeño).
ISO/IEC 27005	Gestión de riesgos de seguridad de la información	Base metodológica de la matriz de riesgos (Sección 06).

Norma	Título	Relevancia para INTERAFAS
ISO 31000:2018	Gestión de riesgos — Directrices	Marco genérico de riesgos al que se alinea ISO/IEC 27005.
ISO/IEC 27019	Controles de seguridad para la industria de energía	Referencia complementaria por el componente OT/SCADA de INTERAFAS.
ISO 22301	Gestión de la continuidad del negocio	Complementa los controles 5.29–5.30 del Anexo A dado el carácter de infraestructura crítica.

2.2 Fase 2 — Selección y justificación de controles del Anexo A (93 controles)

Se revisaron los 93 controles de ISO/IEC 27001:2022 Anexo A (Cláusulas 5 a 8) y se identificaron los que mejor se adecuan al contexto de INTERAFAS, según la investigación de la Sección 01 y los hallazgos del Informe de Seguridad Ofensiva. Cada control se define con **qué es** (su propósito según la norma) y **por qué** aplica específicamente a INTERAFAS.

2.2.1 Controles organizacionales (Cláusula 5)

ID	Control	Qué es	Por qué aplica a INTERAFAS
5.1	Políticas de seguridad de la información	Exige que exista una política de seguridad aprobada, comunicada y revisada periódicamente	INTERAFAS no cuenta hoy con una política formal; es la base de la Sección 05 de este proyecto
5.2	Roles y responsabilidades de seguridad	Exige asignar formalmente quién es responsable de qué en materia de seguridad	El Área de Ciberseguridad tiene solo 4 personas sin roles ni autoridad formalizados
5.7	Inteligencia de amenazas	Exige recopilar y analizar información sobre amenazas emergentes	Como infraestructura crítica, INTERAFAS es blanco de actores de amenaza con motivaciones específicas (sabotaje, extorsión)
5.9	Inventario de información y otros activos asociados	Exige mantener un inventario de activos con propietarios definidos	Es el fundamento directo de los 20 activos de la Sección 04
5.15	Control de acceso	Exige reglas de acceso físico y lógico basadas en requisitos del negocio	Varias vulnerabilidades (IDOR, escalamiento de privilegios) son fallas de control de acceso
5.18	Derechos de acceso	Exige que los derechos de acceso se otorguen, revisen y	Relevante para cuentas administrativas y el padrón de

ID	Control	Qué es	Por qué aplica a INTERAFAS
		retiren formalmente	proveedores
5.19–5.20	Seguridad de la información con proveedores / en acuerdos con proveedores	Exigen gestionar el riesgo de seguridad asociado a terceros	INTERAFAS depende de proveedores externos para contrataciones y posiblemente desarrollo
5.24	Planificación y preparación de la gestión de incidentes	Exige definir procesos, roles y responsabilidades antes de que ocurra un incidente	Base directa del Plan de Respuesta ante Incidentes (entregable 5)
5.26	Respuesta a incidentes de seguridad de la información	Exige responder conforme a procedimientos documentados	Sin este control, cada incidente se atendería de forma improvisada
5.29	Seguridad de la información durante la interrupción	Exige mantener un nivel adecuado de seguridad durante una interrupción del servicio	Crítico dado que INTERAFAS opera infraestructura que no puede detenerse (agua, energía)
5.30	Preparación de las TIC para la continuidad del negocio	Exige planificar, implementar y probar la continuidad de TIC	Relevante para el Centro de Operaciones y la red OT
5.31	Requisitos legales, estatutarios, reglamentarios y contractuales	Exige identificar y mantener actualizado el marco legal aplicable	Base directa de la Sección 2.3 (marco legal)
5.34	Privacidad y protección de PII	Exige cumplir los requisitos de privacidad y protección de datos personales	Directamente vinculado a VULN-03, VULN-10 y VULN-12 (exposición masiva de datos ciudadanos)

2.2.2 Controles de personas (Cláusula 6)

ID	Control	Qué es	Por qué aplica a INTERAFAS
6.3	Concientización, educación y capacitación en seguridad de la	Exige capacitar al personal de forma continua	El personal de desarrollo no ha recibido capacitación formal en desarrollo seguro (hallazgo de la minuta, Sección 07)

ID	Control	Qué es	Por qué aplica a INTERAFAS
	información		
6.8	Informes de eventos de seguridad de la información	Exige un mecanismo para que el personal reporte eventos sospechosos	INTERAFAS no cuenta hoy con un canal formal de reporte (área de oportunidad identificada en 7.1)

2.2.3 Controles físicos (Cláusula 7)

ID	Control	Qué es	Por qué aplica a INTERAFAS
7.1	Perímetros físicos de seguridad	Exige definir y proteger perímetros físicos alrededor de la información	Relevante para el Centro de Operaciones y los cuartos de servidores
7.4	Monitoreo de seguridad física	Exige vigilancia continua del acceso físico no autorizado	Protege estaciones administrativas como WEBOPS-03
7.11	Utilidades de apoyo	Exige proteger las instalaciones contra cortes de energía y fallas de servicios públicos	INTERAFAS es, a la vez, proveedor y consumidor de servicios de infraestructura crítica
7.13	Mantenimiento de equipo	Exige mantener el equipo para garantizar disponibilidad, integridad y confidencialidad	Aplica a los equipos del Centro de Operaciones y de administración de sistemas

2.2.4 Controles tecnológicos (Cláusula 8)

ID	Control	Qué es	Por qué aplica a INTERAFAS
8.2	Derechos de acceso privilegiado	Exige restringir y gestionar los accesos con privilegios elevados	Causa raíz de VULN-06 (escalamiento de privilegios por cookie de rol)
8.3	Restricción de acceso a la información	Exige restringir el acceso según política de control de acceso	Causa raíz de VULN-03 y VULN-12 (IDOR/BOLA)
8.4	Acceso al código fuente	Exige gestionar adecuadamente el acceso de lectura/escritura al código	Vinculado a VULN-04 (exposición de código fuente vía .bak)
8.5	Autenticación segura	Exige tecnologías y procedimientos de autenticación robustos	Vinculado a VULN-10 (fijación de sesión)
8.8	Gestión de vulnerabilidades	Exige obtener información de vulnerabilidades y actuar sobre	Es la justificación misma del proyecto: actuar sobre lo hallado en

ID	Control	Qué es	Por qué aplica a INTERAFAS
	técnicas	ellas	INTERAFAS-LAB
8.9	Gestión de la configuración	Exige establecer y revisar configuraciones seguras	Causa raíz de VULN-01 (Directory Listing habilitado)
8.15	Registro (logging)	Exige producir, proteger y analizar registros de actividad	Necesario para investigar incidentes y sustentar la Sección 09
8.16	Actividades de monitoreo	Exige monitorear redes, sistemas y aplicaciones por comportamiento anómalo	Relevante para detectar explotación activa de las vulnerabilidades identificadas
8.20	Seguridad en redes	Exige asegurar y controlar redes y dispositivos de red	Directamente relevante a la red OT (VULN-17)
8.22	Segregación de redes	Exige separar grupos de servicios, usuarios y sistemas en la red	Causa raíz de VULN-16/VULN-17 (acceso no segmentado a la red OT)
8.24	Uso de criptografía	Exige reglas para el uso efectivo de cifrado	Relevante para proteger PII y credenciales en tránsito y en reposo
8.25	Ciclo de vida de desarrollo seguro	Exige reglas para el desarrollo seguro de software	Atiende la causa raíz transversal de la mayoría de las 17 vulnerabilidades documentadas
8.26	Requisitos de seguridad de la aplicación	Exige identificar y aprobar requisitos de seguridad al desarrollar aplicaciones	Vinculado a VULN-13 (lógica de negocio de pagos) y VULN-14 (validación contractual)
8.28	Codificación segura	Exige aplicar principios de codificación segura	Causa raíz directa de VULN-07 (SQLi) y VULN-08 (XSS almacenado)
8.32	Gestión del cambio	Exige que los cambios en sistemas sigan procedimientos formales	Causa raíz de VULN-01 y VULN-04 (artefactos residuales tras despliegue)

> *En total se seleccionaron **29 controles de los 93 disponibles**, cubriendo las cuatro cláusulas del Anexo A, priorizando aquellos con relación directa y verificable con los hallazgos del Informe de Seguridad Ofensiva y con el contexto institucional de la Sección 01. Esta selección constituye un insumo directo para la futura Declaración de Aplicabilidad (SoA) de INTERAFAS.*

2.3 Marco legal y regulatorio aplicable (de lo federal a lo internacional)

Ámbito municipal/estatal

- Reglamento municipal/estatal de prestación de servicios de agua potable y energía, que regula la operación de INTERAFAS como organismo operador.
- Ley estatal de protección de datos personales en posesión de sujetos obligados (aplicable por ser INTERAFAS un organismo público u organismo descentralizado).
- Ley estatal de transparencia y acceso a la información pública, que obliga a la publicación de contratos y documentos (relevante para A-17/A-18).

Ámbito federal

- Ley Federal de Protección de Datos Personales en Posesión de los Particulares (LFPDPPP) y/o Ley General de Protección de Datos Personales en Posesión de Sujetos Obligados, según la naturaleza jurídica de INTERAFAS, aplicables a los datos personales expuestos en VULN-03, VULN-10 y VULN-12.
- Ley de Aguas Nacionales y su reglamento, por tratarse de un organismo operador de agua.
- Ley General de Transparencia y Acceso a la Información Pública.
- Código de Comercio y Código Fiscal de la Federación, en materia de comprobantes y conservación de registros de facturación (relevante para VULN-13).
- Ley Federal del Trabajo, en lo relativo a confidencialidad y responsabilidades del personal (controles 6.2–6.6 del Anexo A).
- Marco federal de infraestructura crítica / ciberseguridad nacional, aplicable por la naturaleza estratégica de los servicios de INTERAFAS.

Ámbito nacional/sectorial

- Normas Oficiales Mexicanas (NOM) aplicables a calidad de agua y seguridad eléctrica, que, aunque no son de ciberseguridad, condicionan la integridad de los datos de telemetría OT.

Ámbito internacional

- **ISO/IEC 27001:2022**, norma internacional voluntaria que INTERAFAS adopta como marco rector de este proyecto.
- **CISA — Federal Government Cybersecurity Incident and Vulnerability Response Playbooks**, referencia metodológica internacional no vinculante adoptada para el Plan de Respuesta ante Incidentes (entregable 5).
- Marco de Ciberseguridad del NIST (NIST CSF), referencia complementaria de buenas prácticas para la protección de infraestructura crítica, especialmente relevante para la red OT/SCADA.
- En caso de que INTERAFAS procese datos de ciudadanos extranjeros o colabore con organismos internacionales, podría ser relevante el **Reglamento General de Protección de Datos (GDPR)** de la Unión Europea como referencia de buenas prácticas, aunque no es vinculante salvo que exista tratamiento de datos de residentes de la UE.

Sección 03 — Términos y condiciones

De los 81 términos del glosario de la norma ISO/IEC 27001 (basado en ISO/IEC 27000), se seleccionan los siguientes como indispensables para que la Alta Dirección de INTERAFAS contextualice y apruebe el presente proyecto:

#	Término	Definición
1	**Seguridad de la información**	Preservación de la confidencialidad, integridad y disponibilidad de la información.
2	**SGSI (Sistema de Gestión de Seguridad de la Información)**	Conjunto de políticas, procedimientos, directrices y recursos asociados, gestionados colectivamente por la organización, para proteger sus activos de información.
3	**Activo de información**	Todo elemento (datos, sistemas, documentos, infraestructura) que tiene valor para la organización y que, por tanto, requiere protección.
4	**Riesgo de seguridad de la información**	Efecto de la incertidumbre sobre los objetivos de seguridad de la información, generalmente expresado como combinación de probabilidad e impacto de un evento.
5	**Amenaza**	Causa potencial de un incidente no deseado que puede ocasionar daño a un sistema u organización.
6	**Vulnerabilidad**	Debilidad de un activo o control que puede ser explotada por una o más amenazas.
7	**Control**	Medida que modifica el riesgo de seguridad de la información (puede ser una política, un procedimiento, una práctica técnica u organizativa).
8	**Incidente de seguridad de la información**	Evento o serie de eventos no deseados o inesperados que tienen una probabilidad significativa de comprometer las operaciones y amenazar la seguridad de la información.
9	**Declaración de Aplicabilidad (SoA)**	Documento que enumera los controles necesarios del Anexo A, indica si se aplican y justifica su inclusión o exclusión.
10	**Tratamiento de riesgos**	Proceso para seleccionar e implementar las medidas que modifican el riesgo (aceptar, evitar, transferir o mitigar).

> *Estos diez términos son la base conceptual común que la Alta Dirección, el área de Ciberseguridad y los responsables de proceso utilizarán de forma consistente a lo largo de todo este documento y de los entregables 4 y 5 del proyecto.*

Sección 04 — Contexto de la organización

4.1 Cuestiones externas e internas (Cláusula 4.1)

Internas: transformación digital acelerada sin gobierno de seguridad maduro; dependencia de personal reducido de TI; coexistencia de sistemas legados (archivos .bak, respaldos sin depurar) con desarrollos nuevos; cultura organizacional orientada a disponibilidad del servicio por encima de la seguridad.

Externas: marco legal de protección de datos en evolución; exposición pública como infraestructura crítica (objetivo atractivo para actores de amenaza); relación con proveedores y contratistas externos con acceso a sistemas de contratación; expectativa ciudadana de transparencia y disponibilidad continua del servicio.

4.2 Partes interesadas (Cláusula 4.2)

Ciudadanos/usuarios del servicio, Alta Dirección, personal operativo (Centro de Operaciones OT), área de Desarrollo y Plataformas Web, proveedores y contratistas, autoridades reguladoras de protección de datos e infraestructura crítica, medios de comunicación.

4.3 Inventario de 20 activos de información (10 internos / 10 externos)

> ***Criterio de clasificación:*** *un activo es* ***interno*** *cuando está bajo la administración directa de INTERAFAS (la organización lo posee, opera y controla); es* ***externo*** *cuando* ***no depende de la administración de INTERAFAS****, aun cuando sea indispensable para su operación (p. ej. un proveedor, Internet, el dispositivo de un ciudadano o el suministro eléctrico de la red pública).*

Activos internos (10) — bajo administración directa de INTERAFAS

ID	Activo de información	Incluye	Vinculación con hallazgos
I-01	Código fuente y artefactos de despliegue (backend/frontend)	Repositorios, pipeline CI/CD, paquetes .zip	VULN-01, VULN-04, VULN-07, VULN-09, VULN-13
I-02	Base de datos INTERAFAS (incluye PII y datos financieros)	Motor SQL, esquemas, expedientes ciudadanos	VULN-03, VULN-07, VULN-10, VULN-12
I-03	Archivos de configuración y variables de entorno	Secretos, tokens, .env, y configuraciones operativas y firmware (JSON)	VULN-01, VULN-02, VULN-20
I-04	Sistema de gestión de sesiones y credenciales (incluye cuentas privilegiadas)	Autenticación, roles, cookies de sesión	VULN-05, VULN-06, VULN-10, VULN-17
I-05	Red operacional (OT), telemetría/SCADA e infraestructura de planta expuesta	HMI, actuadores, API de telemetría	VULN-16, VULN-17, VULN-18

ID	Activo de información	Incluye	Vinculación con hallazgos
I-06	Portal web institucional y APIs de servicios ciudadanos (incluye facturación y pagos)	Portal público, API de historial, pago.php	VULN-01 a VULN-05, VULN-08, VULN-11, VULN-12, VULN-13
I-07	Sistema de reportes ciudadanos, documentos de transparencia y comunicación institucional	reportes.php, documentos públicos, vocería	VULN-04, VULN-08
I-08	Padrón de proveedores, contrataciones y vínculos contractuales	proveedores.php, validación de vínculos	VULN-14
I-09	Bitácoras, registros de auditoría y documentación interna de arquitectura	Logs, documentación de APIs y modelo de dependencias/topología OT	VULN-02, VULN-09, VULN-11, VULN-15, VULN-19
I-10	Equipos y estaciones de administración de sistemas	Estaciones WEBOPS, accesos administrativos	VULN-01

Activos externos (10) — no dependen de la administración de INTERAFAS

ID	Activo / dependencia externa	Por qué procesa, almacena o transmite información de INTERAFAS
E-01	Conectividad a Internet y proveedores de servicio de Internet (ISP)	Transporta todo el tráfico hacia el portal, las APIs y la red OT
E-02	Infraestructura de hosting / nube de terceros utilizada para alojar servicios	Almacena y procesa cargas de trabajo de INTERAFAS fuera de sus instalaciones
E-03	Dispositivos, navegadores y redes de los ciudadanos/usuarios finales	Procesan y transmiten las credenciales y datos que el ciudadano introduce
E-04	Sistemas propios de los proveedores y contratistas externos	Intercambian información contractual y de facturación con INTERAFAS
E-05	Pasarela de pagos bancaria (SPEI) operada por una institución financiera	Procesa las transacciones de cobro de los usuarios
E-06	Medios de comunicación, prensa y redes sociales	Difunden y amplifican información (veraz o no) sobre INTERAFAS
E-07	Autoridades regulatorias y organismos de protección de datos	Reciben y custodian reportes de cumplimiento e incidentes
E-08	Infraestructura de nombres de dominio (DNS) y autoridades certificadoras (CA) de terceros	Resuelven y autentican el acceso al portal institucional

ID	Activo / dependencia externa	Por qué procesa, almacena o transmite información de INTERAFAS
E-09	Cadena de suministro de software (librerías de código abierto, componentes de terceros)	Forman parte del código que procesa la información de INTERAFAS
E-10	Suministro eléctrico externo y condiciones ambientales de la red pública	Determinan la disponibilidad física de la planta y del centro de datos

Estos 20 activos son la base de las políticas funcionales (Sección 05) y de la matriz de riesgos (Sección 06).

Sección 05 — Liderazgo

5.1 Política general de seguridad de la información

La Alta Dirección de INTERAFAS establece su compromiso con la protección de la confidencialidad, integridad y disponibilidad de la información y los activos tecnológicos que soportan los servicios de infraestructura crítica. INTERAFAS se compromete a: (a) cumplir los requisitos legales, regulatorios y contractuales aplicables; (b) establecer objetivos medibles de seguridad de la información; (c) asignar los recursos necesarios para el SGSI; (d) mejorar continuamente el SGSI con base en los resultados de auditoría, evaluación de riesgos e incidentes; y (e) comunicar esta política a todo el personal, proveedores y partes interesadas relevantes. Esta política es revisada anualmente o ante cambios significativos en el contexto de la organización.

5.2 Jerarquía de políticas

De la Política General se desprenden **Políticas Generales** por dominio, y de cada una de estas se desprenden las **Políticas Funcionales** específicas por activo:

```
Política General (5.1 — compromiso institucional de Alta Dirección)
 └── Políticas Generales (por dominio)
      └── Políticas Funcionales (20 — una por activo de información)
```

Cada política funcional se compone de cuatro elementos:

- **Estándar:** lo que debe hacerse (obligatorio).
- **Directriz:** lo que se recomienda hacer (orientación, no obligatoria en sí misma).
- **Procedimiento:** cómo hacer algo específico (pasos concretos).
- **Línea base:** el punto de partida / el mínimo aceptable contra el cual se mide el cumplimiento.

Políticas Generales por dominio

Dominio	Política General	Activos que cubre
Desarrollo y plataformas	Toda aplicación de INTERAFAS debe desarrollarse, desplegarse y mantenerse bajo prácticas de desarrollo seguro	I-01, I-02, I-03, I-06, I-07

Dominio	Política General	Activos que cubre
Identidad y acceso	El acceso a sistemas e información se otorga por rol, se valida siempre del lado del servidor y se revisa periódicamente	I-04, I-10
Infraestructura crítica y OT	La red operacional se protege con segmentación y defensa en profundidad, nunca solo por perímetro	I-05
Terceros y cadena de suministro	Todo proveedor, servicio externo o componente de terceros debe evaluarse y gestionarse en función del riesgo que introduce	I-08, E-01 a E-05, E-08, E-09
Cumplimiento, comunicación y continuidad	INTERAFAS gestiona de forma proactiva su exposición legal, reputacional y operativa ante terceros fuera de su control	I-07, I-09, E-06, E-07, E-10

5.3 Políticas funcionales (20): 10 internas + 10 externas

5.3.1 Políticas funcionales — Activos internos (I-01 a I-10)

ID	Activo	Política funcional	Estándar	Directriz	Procedimiento	Línea base
PF-01	I-01 Código y despliegue	Protección del código fuente y limpieza de artefactos de despliegue	8.4 / 8.32 — El código y los artefactos de despliegue no deben ser accesibles públicamente	Se recomienda usar repositorio privado con revisión de cambios (pull request)	Automatizar en el pipeline CI/CD la eliminación de .bak/.zip/.env tras cada despliegue	0 archivos residuales accesibles desde el document root
PF-02	I-02 Base de datos / PII	Seguridad de consultas y protección de datos personales	8.28 / 5.34 — Toda consulta a la BD debe usar Prepared Statements; la PII debe cifrarse en reposo	Se recomienda mínimo privilegio para el usuario de base de datos	Revisión de código obligatoria (SAST) antes de cada despliegue	100% de endpoints con Prepared Statements (PDO)
PF-03	I-03 Configuración/secretos	Gestión segura de configuración	8.9 — Los secretos nunca se almacenan en texto plano accesible	Se recomienda usar un gestor de secretos	Automatizar la limpieza de .env/.zip/.bak en	Cero archivos de configuración expuestos

ID	Activo	Política funcional	Estándar	Directriz	Procedimiento	Línea base
			públicamente	(vault)	producción	
PF-04	I-04 Sesiones/privilegios	Gestión segura de sesión y de accesos privilegiados	8.5 / 8.2 — El rol se determina server-side; la sesión se regenera en cada cambio de privilegio	Se recomienda MFA para cuentas administrativas	session_regenerate_id() tras login; rol leído de $_SESSION, nunca de cookie	0 endpoints que confíen en rol enviado por el cliente
PF-05	I-05 Red OT/SCADA	Defensa en profundidad de la red operacional	8.20 / 8.22 — El acceso a la red OT exige autenticación, no solo origen de red	Se recomienda enfoque Zero Trust para todo endpoint OT	Middleware de validación de sesión en /operations/	0 accesos a datos de planta sin sesión operacional activa
PF-06	I-06 Portal/API/pagos	Autorización a nivel de objeto e integridad de la lógica de pagos	8.3 / 8.26 — Toda solicitud valida propiedad del recurso; el monto a cobrar se calcula server-side	Se recomienda eliminar Directory Listing y depurar robots.txt	Extraer identificador de cuenta de la sesión; eliminar parámetro "monto" del POST	0 accesos cruzados entre cuentas; 0 pagos aplicados por monto distinto al saldo
PF-07	I-07 Reportes/documentos/comunicación	Codificación de salida y control de archivos públicos	8.28 — Todo contenido generado por usuario se codifica antes de mostrarse	Se recomienda implementar CSP	htmlspecialchars() con ENT_QUOTES |ENT_HTML5; regla FilesMatch contra extensiones de respaldo	0 scripts inyectados; 0 archivos de respaldo descargables
PF-08	I-08 Proveedores/contratos	Validación relacional de vínculos contractuales	8.26 — Toda validación contractual exige coincidencia exacta	Se recomienda registro firmado de cada	Consultas con JOIN estricto entre contrato y proveedor	0 validaciones positivas falsas en pruebas de casos

ID	Activo	Política funcional	Estándar	Directriz	Procedimiento	Línea base
			contrato-proveedor	validación		negativos
PF-09	I-09 Logs/documentación	Registro protegido y minimización de metadatos expuestos	8.15 — Los registros críticos se protegen contra alteración	Se recomienda centralizar logs fuera del servidor de aplicación	Eliminar cabeceras y rutas de depuración del código de producción	Retención mínima 90 días; 0 cabeceras X-INTERAFAS-* públicas
PF-10	I-10 Equipos de administración	Protección de endpoints administrativos	8.1 — Los equipos administrativos requieren controles reforzados	Se recomienda cifrado de disco completo	Aplicar hardening y MFA en estaciones WEBOPS	100% de equipos administrativos con MFA habilitado

5.3.2 Políticas funcionales — Activos externos (E-01 a E-10)

ID	Activo	Política funcional	Estándar	Directriz	Procedimiento	Línea base
PF-11	E-01 Internet/ISP	Continuidad ante interrupción del enlace a Internet	5.30 — Debe existir un plan de continuidad de TIC ante falla del proveedor de enlace	Se recomienda contratar enlace redundante (dual ISP)	Activar el plan de continuidad si la indisponibilidad supera el SLA pactado	Acuerdo de nivel de servicio (SLA) firmado con el o los ISP
PF-12	E-02 Hosting/nube de terceros	Gestión del riesgo en servicios de terceros	5.23 — Los servicios en la nube se adquieren y gestionan conforme a los requisitos de seguridad de INTERAFAS	Se recomienda exigir certificaciones de seguridad al proveedor (ISO/IEC 27001 propia)	Incluir cláusulas de seguridad y auditoría en el contrato de hosting	Contrato vigente con cláusulas de seguridad revisadas anualmente
PF-13	E-03	Mitigación	8.5 — La	Se	Validar toda	0 decisiones

ID	Activo	Política funcional	Estándar	Directriz	Procedimiento	Línea base
	Dispositivos ciudadanos	del riesgo no controlable del lado del cliente	seguridad del sistema no depende de la integridad del dispositivo del usuario final	recomienda reforzar validaciones server-side precisamente porque el cliente no es confiable	entrada del usuario exclusivamente en el servidor	de seguridad delegadas al navegador/ dispositivo del ciudadano
PF-14	E-04 Sistemas de proveedores	Evaluación de seguridad de terceros	5.19 / 5.20 — Se deben gestionar los riesgos asociados al uso de sistemas de proveedores	Se recomienda cuestionario de seguridad previo al alta de cada proveedor	Evaluación anual de seguridad de proveedores con acceso al padrón	100% de proveedores con acceso evaluados anualmente
PF-15	E-05 Pasarela de pagos bancaria	Gestión del riesgo de disponibilidad y fraude en pagos de terceros	5.19 — Se deben definir requisitos de seguridad con la institución financiera	Se recomienda monitoreo activo de transacciones atípicas	Conciliación diaria automatizada de pagos recibidos vs. facturas	100% de transacciones conciliadas diariamente
PF-16	E-06 Medios/redes sociales	Gobierno de la comunicación de crisis	5.24 — Debe existir un proceso de gestión de incidentes que incluya comunicación externa	Se recomienda vocería única durante una crisis	Activación del Plan de Comunicación de Crisis (entregable 4)	Ver entregable 4 — Plan de Comunicación de Crisis
PF-17	E-07 Autoridades regulatorias	Cumplimiento regulatorio proactivo	5.31 — Los requisitos legales deben identificarse y mantenerse actualizados	Se recomienda designar un enlace formal con el regulador	Reporte periódico de cumplimiento a la Dirección Jurídica	Marco legal de la Sección 2.3 revisado anualmente
PF-18	E-08 DNS/certificados de	Continuidad del nombre de dominio y de la	8.24 — El uso de criptografía (certificados TLS) debe gestionarse	Se recomienda renovación automática	Monitoreo de expiración de dominio	0 interrupciones por expiración

ID	Activo	Política funcional	Estándar	Directriz	Procedimiento	Línea base
	terceros	autenticación TLS	activamente	de certificados	y certificado con alerta a 30 días	de dominio o certificado
PF-19	E-09 Cadena de suministro de software	Gestión de vulnerabilidades en componentes de terceros	8.8 — Se debe obtener información de vulnerabilidades de dependencias y actuar sobre ellas	Se recomienda usar herramientas de análisis de composición de software (SCA)	Escaneo automatizado de dependencias en cada build	0 dependencias con vulnerabilidades críticas conocidas sin parchar
PF-20	E-10 Suministro eléctrico/ambiente	Continuidad operativa ante interrupción externa	7.11 — Las instalaciones deben protegerse contra cortes de energía y fallas de servicios públicos	Se recomienda contar con generación de respaldo (UPS/planta)	Prueba periódica de los sistemas de respaldo eléctrico	Autonomía mínima garantizada ante corte de suministro externo

---

Sección 06 — Planificación

6.1 Criterios de riesgo

Probabilidad: Baja (1) · Media (2) · Alta (3). **Impacto:** Bajo (1) · Medio (2) · Alto (3) · Crítico (4). **Nivel de riesgo** = Probabilidad × Impacto → Bajo (1–3) · Moderado (4–6) · Alto (7–9) · Crítico (10–12). Criterio de aceptación: solo se aceptan riesgos de nivel **Bajo**; todo riesgo Moderado, Alto o Crítico requiere tratamiento y aprobación del propietario del riesgo (Dirección de TI).

6.2 Matriz de riesgos (una amenaza por política funcional)

ID	Activo	Amenaza identificada	Prob.	Impacto	Nivel	Tratamiento
R-01	I-01	Exposición de código fuente y artefactos residuales (.bak)	3	4	Crítico	Mitigar — limpieza automatizada de despliegue
R-02	I-02	Inyección SQL y exposición masiva de PII	3	4	Crítico	Mitigar — Prepared Statements + cifrado

ID	Activo	Amenaza identificada	Prob.	Impacto	Nivel	Tratamiento
						de PII
R-03	I-03	Fuga de credenciales vía .env en directorios listables	3	4	Crítico	Mitigar — deshabilitar Directory Listing
R-04	I-04	Secuestro de sesión y escalamiento de privilegios por cookie de rol	3	4	Crítico	Mitigar — rol server-side, regeneración de sesión
R-05	I-05	Acceso no autorizado a telemetría de planta	2	4	Alto	Mitigar — middleware de validación de sesión en OT
R-06	I-06	IDOR/BOLA en API y fraude en monto de pago	3	4	Crítico	Mitigar — autorización por objeto + cálculo server-side
R-07	I-07	XSS almacenado y descarga fuera de directorio (LFI)	2	4	Alto	Mitigar — codificación de salida + identificadores indirectos
R-08	I-08	Falsificación de vínculos contractuales	1	4	Moderado	Mitigar — validación relacional estricta
R-09	I-09	Alteración de bitácoras y reconocimiento vía cabeceras	2	2	Moderado	Mitigar — centralización de logs, limpieza de cabeceras
R-10	I-10	Compromiso de estación administrativa	1	4	Moderado	Mitigar — MFA y hardening
R-11	E-01	Interrupción del enlace a Internet/ISP	2	3	Moderado	Transferir — SLA con proveedor, enlace redundante
R-12	E-02	Incidente de seguridad en el proveedor de hosting/nube	2	4	Alto	Transferir/Mitigar — cláusulas contractuales de seguridad
R-13	E-03	Dispositivo del ciudadano	2	3	Moderado	Mitigar — reforzar validación server-side

ID	Activo	Amenaza identificada	Prob.	Impacto	Nivel	Tratamiento
		comprometido (malware, phishing)				
R-14	E-04	Proveedor externo comprometido facilita acceso indebido	2	4	Alto	Mitigar — evaluación anual de seguridad de proveedores
R-15	E-05	Indisponibilidad o fraude en la pasarela de pagos bancaria	2	4	Alto	Transferir — SLA y conciliación diaria con el banco
R-16	E-06	Crisis reputacional por cobertura mediática de un incidente	3	3	Alto	Mitigar/Transferir parcialmente — Plan de Comunicación de Crisis
R-17	E-07	Sanción regulatoria por incumplimiento detectado por la autoridad	2	3	Moderado	Mitigar — cumplimiento legal proactivo (Sección 2.3)
R-18	E-08	Secuestro de dominio o expiración de certificado TLS	2	3	Moderado	Mitigar — monitoreo y renovación automática
R-19	E-09	Vulnerabilidad explotada en librería/dependencia de terceros	2	4	Alto	Mitigar — escaneo SCA en cada build
R-20	E-10	Corte de energía externo o evento ambiental en la planta	2	4	Alto	Mitigar — respaldo eléctrico (UPS/planta)
R-21	I-05	Falsificación de firmware OT por validación criptográfica deficiente y uso de SHA-1	3	4	Critico	Mitigar — Implementar firma digital asimétrica (Code Signing) en actualizaciones
R-22	I-09	Reconocimiento pasivo de topología OT y dependencias por exceso de privilegios	3	4	Critico	Mitigar — RBAC estricto para ocultar cadena a soporte y limpiar cabeceras `X-INTERAFAS-*`

ID	Activo	Amenaza identificada	Prob.	Impacto	Nivel	Tratamiento
R-23	I-03 / I-05	Sabotaje físico (Catastrophic State) por inyección de parámetros operativos sin validación	3	4	Critico	Mitigar — Validación estricta de límites (Sanity Checks) para setpoints en archivos JSON

6.3 Plan de tratamiento

Los riesgos de nivel **Crítico** (R-01, R-02, R-03, R-04, R-06 — todos sobre activos internos) se atienden en los primeros 30 días del proyecto por ser consecuencia directa de vulnerabilidades ya confirmadas en la auditoría ofensiva. Los de nivel **Alto** se atienden en 90 días. Los de nivel **Moderado** se incorporan al backlog de mejora continua (Sección 10). El propietario de riesgo para los activos internos (I-01 a I-10) es la Dirección de Tecnologías de la Información; para los activos externos (E-01 a E-10) el propietario depende del dominio: Dirección Administrativa y de Proveedores (E-02, E-04), Dirección Jurídica y Cumplimiento (E-07, E-08), Dirección de Atención Ciudadana y Comunicación Social (E-06), y Dirección de Operaciones (E-10).

Sección 07 — Soporte

7.1 Minuta de arranque del SGSI

Reunión: Kickoff del Sistema de Gestión de Seguridad de la Información — INTERAFAS **Asistentes:** Dirección General, Dirección de TI y Operaciones, Área de Ciberseguridad y Gobierno de TI, Dirección Jurídica y Cumplimiento, Dirección de Atención Ciudadana y Comunicación Social.

Puntos tratados:

1. Presentación de los hallazgos del Informe de Seguridad Ofensiva (20 vulnerabilidades identificadas y confirmadas con evidencia técnica, incluyendo riesgos críticos de infraestructura OT).
2. Presentación del alcance del SGSI y las 20 políticas funcionales (Sección 05).
3. Presentación de la matriz de riesgos y priorización de los 5 riesgos críticos (Sección 06).

Acuerdos:

- Se aprueba el alcance del SGSI definido en la Sección 1.3.
- La Dirección de TI designa a un responsable de seguridad de la información (Oficial de Seguridad) como propietario operativo del SGSI.
- Se autoriza el tratamiento inmediato (30 días) de los 5 riesgos críticos (R-01, R-02, R-03, R-04, R-06).
- Se aprueba el desarrollo del soporte documental de prevención descrito en 7.2.

Áreas de oportunidad identificadas:

- No existe un proceso formal de gestión de cambios que incluya verificación de seguridad previa al despliegue.
- El personal de desarrollo no ha recibido capacitación formal en desarrollo seguro (OWASP, codificación segura).
- No existe un canal formal para que el personal reporte eventos de seguridad sospechosos (control 6.8 del Anexo A).

7.2 Soporte documental de prevención (derivado de la matriz de riesgos)

Formato	Público objetivo	Contenido (basado en riesgos R-01 a R-20)
Flyer "Despliega seguro: checklist de 5 pasos"	Equipo de Desarrollo y Plataformas Web	Verificación de ausencia de .env/.bak/.zip, Directory Listing deshabilitado, y pruebas de autorización por objeto antes de cada publicación (R-01, R-03, R-04, R-12).
Presentación ejecutiva "De la auditoría a la gobernanza"	Alta Dirección y mandos medios	Resumen de los 20 hallazgos, impacto en continuidad e imagen institucional, y el plan de tratamiento de riesgos críticos.
Curso corto "Desarrollo seguro para APIs ciudadanas" (4 horas)	Desarrolladores backend/frontend	Autorización a nivel de objeto (BOLA), consultas parametrizadas, codificación de salida contra XSS, gestión segura de sesiones.
Video de concientización "No confíes en el cliente" (3–5 min)	Todo el personal técnico	Casos reales simplificados de INTERAFAS-LAB: manipulación de cookies de rol, manipulación de montos de pago y por qué toda validación debe vivir en el servidor.

Estos cuatro productos conforman el soporte de prevención inicial; su efectividad se revisa en la Sección 10 (Mejora) a partir de los resultados de las listas de verificación de auditoría (Sección 09).

7.3 Anexo — Soporte documental de prevención (contenido completo)

7.3.1 Flyer — "Despliega seguro: checklist de 5 pasos"

DESPLIEGA SEGURO Checklist de 5 pasos antes de publicar Área de Ciberseguridad y Gobierno de TI — INTERAFAS

Antes de dar clic en "publicar", verifica:

1. **Archivos residuales** — ¿Eliminaste todo .env, .bak, .zip, .old y .git del entorno de producción?
2. **Directory Listing** — ¿Está deshabilitado (Options -Indexes) en cada carpeta del sitio?
3. **Consultas a base de datos** — ¿Usan Prepared Statements (PDO)? ¿Ninguna concatena entrada del usuario directamente?
4. **Autorización por objeto** — ¿Cada endpoint valida que el recurso solicitado pertenece al usuario de la sesión, y no a un ID recibido por parámetro?

5. **Sesión y rol** — ¿El rol del usuario se lee del servidor ($_SESSION) y nunca de una cookie o parámetro enviado por el cliente?

> *Si respondiste "no" a cualquier punto, **no publiques** — corrige primero y vuelve a correr este checklist.*

¿Encontraste una vulnerabilidad? Repórtala de inmediato al Área de Ciberseguridad: [canal interno de reporte].

Referencia: controles 8.4, 8.9, 8.28 y 8.2 de ISO/IEC 27001:2022 Anexo A — ver Sección 05 de este documento.

7.3.2 Presentación ejecutiva — "De la auditoría a la gobernanza" (guion de diapositivas)

#	Título de la diapositiva	Contenido clave
1	De la auditoría a la gobernanza	Portada: INTERAFAS, SGSI ISO/IEC 27001, fecha de presentación al Comité
2	¿Por qué estamos aquí?	Resumen de INTERAFAS-LAB: 17 de 20 vulnerabilidades confirmadas con evidencia técnica
3	Lo que encontramos	Las 5 vulnerabilidades críticas y su relación con los activos I-01 a I-10 (Sección 04)
4	El riesgo real	Matriz de riesgos resumida: 5 críticos, 7 altos, 8 moderados (Sección 06)
5	Qué estamos haciendo	Las 20 políticas funcionales y su jerarquía (Política General → Generales → Funcionales)
6	Quién hace qué	Matriz RACI resumida (Sección 08)
7	Cómo sabremos que funciona	Indicadores de la Sección 09: checklist trimestral de 12 controles críticos
8	Lo que necesitamos de ustedes	Aprobación del presupuesto y recursos del Área de Ciberseguridad (hoy 4 personas)
9	Próximos pasos	Calendario: 30 días (críticos), 90 días (altos), ciclo continuo (moderados)
10	Preguntas	Cierre y espacio para preguntas de la Alta Dirección

7.3.3 Curso corto — "Desarrollo seguro para APIs ciudadanas" (temario, 4 horas)

Módulo	Duración	Contenido	Ejercicio práctico
1. El cliente no es confiable	30 min	Por qué toda validación debe vivir en el servidor; casos reales de	Identificar en código real dónde se confía

Módulo	Duración	Contenido	Ejercicio práctico
		INTERAFAS-LAB (cookie de rol, parámetro de monto)	indebidamente en el cliente
2. Autorización a nivel de objeto (BOLA/IDOR)	60 min	Qué es, cómo se explota, cómo prevenirla	Corregir un endpoint vulnerable a IDOR (ejercicio guiado)
3. Consultas seguras a base de datos	60 min	Prepared Statements, por qué la concatenación de strings es peligrosa	Reescribir 3 consultas vulnerables a SQLi
4. Codificación de salida y XSS	45 min	htmlspecialchars(), Content-Security-Policy	Neutralizar un payload de XSS almacenado
5. Gestión segura de sesiones	30 min	Fijación de sesión, regeneración de ID, cookies seguras	Implementar session_regenerate_id() en un flujo de login
6. Cierre y evaluación	15 min	Checklist final (ver flyer 7.3.1) y quiz de 10 preguntas	Quiz individual, mínimo 8/10 para acreditar

7.3.4 Video de concientización — "No confíes en el cliente" (guion, 3–5 min)

Tiempo	Escena	Narración / texto en pantalla
0:00–0:30	Apertura	"En INTERAFAS-LAB encontramos que un atacante podía convertirse en administrador cambiando una sola cookie. Así es como pasó."
0:30–1:30	Caso 1 — Escalamiento de privilegios	Animación simple: usuario normal edita portal_role=admin en el navegador y obtiene acceso administrativo. Texto: "El servidor confió en un dato que el usuario puede modificar libremente."
1:30–2:30	Caso 2 — Manipulación de monto de pago	Animación: usuario intercepta el formulario de pago y cambia el campo monto antes de enviarlo. Texto: "Si el precio se calcula en el navegador, el navegador decide el precio."
2:30–3:30	La regla de oro	Texto en pantalla grande: "TODA decisión de seguridad se valida en el servidor. Siempre."
3:30–4:00	Cierre	"Antes de tu próximo despliegue, usa el checklist de 5 pasos." Llamado a la acción: enlace al flyer (7.3.1)

Formato de entrega: video corto para reproducirse en la inducción de nuevo personal de desarrollo y en la capacitación anual de concientización (control 6.3 del Anexo A).

Sección 08 — Operación

8.1 Planificación y control operativo

La implementación de las 20 políticas funcionales y el tratamiento de los 20 riesgos identificados se ejecuta mediante procesos controlados con criterios de aceptación definidos (líneas base de la Sección 05) y evaluación previa a cada cambio en producción (control de cambios, 8.32 del Anexo A).

8.2 Matriz RACI del proyecto SGSI

Responsable (ejecuta) · **A**probador (rinde cuentas) · **C**onsultado · **I**nformado

Actividad	Dirección General	Dirección de TI y Operaciones	Oficial de Seguridad (Ciberseguridad)	Desarrollo y Plataformas Web	Centro de Operaciones (OT)	Jurídico y Cumplimiento	Atención Ciudadana y Comunicación
Aprobar política general de seguridad (5.1)	A	R	C	I	I	C	I
Definir y mantener las 20 políticas funcionales (5.2)	I	A	R	C	C	C	I
Evaluación y tratamiento de riesgos (Sección 06)	I	A	R	C	C	I	I
Corrección de vulnerabilidades técnicas (código, BD,	I	A	C	R	I	I	I

Actividad	Dirección General	Dirección de TI y Operaciones	Oficial de Seguridad (Ciberseguridad)	Desarrollo y Plataformas Web	Centro de Operaciones (OT)	Jurídico y Cumplimiento	Atención Ciudadana y Comunicación
sesiones)							
Hardening de la red OT y telemetría	I	A	C	I	R	I	I
Elaboración de soporte documental de prevención (7.2)	I	C	R	C	C	I	A
Cumplimiento legal y protección de datos personales	I	C	C	I	I	R/A	I
Auditoría interna y listas de verificación (Sección 09)	I	A	R	C	C	C	I
Activación del Plan de Comunicación de Crisis (entregable 4)	A	C	C	I	I	C	R
Activación del Plan	I	A	R	C	C	C	C

Actividad	Dirección General	Dirección de TI y Operaciones	Oficial de Seguridad (Ciberseguridad)	Desarrollo y Plataformas Web	Centro de Operaciones (OT)	Jurídico y Cumplimiento	Atención Ciudadana y Comunicación
de Respuesta ante Incidentes (entregable 5)							
Revisión por la Dirección y mejora continua (Sección 10)	A	R	C	I	I	I	I

> *Donde aparece "R/A" el rol es responsable y aprobador simultáneamente dado el carácter especializado de la función (cumplimiento legal).*

Sección 09 — Evaluación del desempeño

9.1 Seguimiento y medición

La Dirección de TI y Operaciones, a través del Oficial de Seguridad, da seguimiento trimestral al cumplimiento de las 20 políticas funcionales mediante las listas de verificación siguientes. Los resultados se analizan en la revisión por la Dirección (9.3) y alimentan la mejora continua (Sección 10).

9.2 Lista de verificación de auditoría interna — Controles técnicos críticos

#	Verificación	Cumple (Sí/No)	Evidencia esperada
1	El servidor web tiene Directory Listing deshabilitado (Options -Indexes)		Captura de respuesta 403 al listar directorios
2	No existen archivos .env, .bak, .zip accesibles públicamente		Resultado de escaneo de extensiones sensibles
3	Todas las consultas a base de datos usan Prepared Statements		Revisión de código / resultado de SAST
4	Las sesiones se regeneran tras un cambio		Prueba de PHPSESSID

#	Verificación	Cumple (Sí/No)	Evidencia esperada
	de privilegio		antes/después del login
5	El rol de usuario se valida exclusivamente del lado del servidor		Prueba de manipulación de cookie portal_role
6	Los endpoints de la API validan la propiedad del recurso solicitado (anti-IDOR)		Prueba de acceso cruzado entre cuentas
7	La salida HTML codifica caracteres especiales en campos de usuario		Prueba de payload XSS en formularios
8	El parámetro de descarga de documentos no permite path traversal		Prueba con secuencias ../
9	El monto de pago se calcula server-side y no se recibe del cliente		Revisión del payload POST de pago.php
10	La red OT exige sesión válida, no solo origen de red		Prueba de acceso a /operations/telemetry.php sin cookie
11	Las cabeceras HTTP de depuración (X-INTERAFAS-*) no están presentes en producción		Inspección de Response Headers
12	Existe registro trazable de cada validación de vínculo contractual		Muestra de bitácora de validaciones
13	El mecanismo de actualización de firmware OT verifica la autenticidad mediante firma criptográfica asimétrica		Intento de instalación de paquete manipulado sin firma es rechazado por el servidor
14	Los roles de soporte y mantenimiento tienen restringida la visibilidad de la topología y cadena de dependencias		Petición a `/asset-context.php` con rol maintenance devuelve acceso denegado
15	El sistema rechaza configuraciones JSON con parámetros físicos (setpoints) fuera de los rangos operativos seguros		Carga de archivo con presión anómala (ej. 10) es bloqueada con error de límites

9.3 Revisión por la Dirección

La Alta Dirección revisa trimestralmente: (a) resultados de las listas de verificación anteriores; (b) estado del plan de tratamiento de riesgos (Sección 6.3); (c) incidentes reportados y acciones correctivas; (d) retroalimentación de auditoría interna; y (e) oportunidades de mejora continua, de las cuales se desprenden las acciones documentadas en la Sección 10.

Sección 10 — Mejora

10.1 Hallazgo de la auditoría que detona la mejora

Al aplicar la lista de verificación de la Sección 9.2 en el primer ciclo trimestral, el ítem **#9** ("El monto de pago se calcula server-side") resulta **No cumple**: durante la auditoría se confirma que la política **PF-06 — Autorización a nivel de objeto e integridad de la lógica de pagos** (activo I-06, vinculada al riesgo R-06 y al hallazgo VULN-13 del informe original) no alcanzó su objetivo, ya que el campo monto seguía siendo editable desde el cliente en una ruta alterna de pago no cubierta por la corrección inicial.

10.2 No conformidad y acción correctiva (Cláusula 10.2)

Elemento	Detalle
No conformidad	PF-06 no se aplicó a todas las rutas de pago; solo se corrigió el flujo principal de pago.php
Causa raíz	La corrección se validó únicamente en el escenario de prueba documentado en VULN-13, sin mapear todas las rutas de negocio que invocan la misma lógica de cobro
Acción correctiva	Auditar e inventariar **todas** las rutas que procesan pagos (incluyendo integraciones futuras), aplicando la regla "el servidor siempre calcula el monto" de forma centralizada en una única función de negocio reutilizable, no por endpoint
Verificación de efectividad	Repetir la prueba de manipulación de monto en cada ruta de pago identificada; cerrar la no conformidad solo cuando el 100% de las rutas pasen la prueba

10.3 Rediseño del soporte de prevención (a partir del checklist de auditoría)

Con base en los resultados del primer ciclo de auditoría (Sección 9.2), el soporte documental de prevención (Sección 7.2) se rediseña así:

- **Flyer de despliegue:** se agrega un punto de verificación específico "¿Existen rutas de pago o cobro no cubiertas por la validación server-side?".
- **Curso corto de desarrollo seguro:** se incorpora un módulo nuevo sobre "centralización de lógica de negocio crítica" para evitar que una misma regla de validación se implemente de forma inconsistente en distintos endpoints.

- **Video de concientización:** se añade un segundo caso basado en la no conformidad de P-14, mostrando cómo una corrección parcial sigue dejando expuesta a la organización.
- Se programa una **re-auditoría dirigida** (no el ciclo trimestral completo) específicamente sobre el ítem #9 a los 30 días de aplicada la acción correctiva.

10.4 Mejora continua

INTERAFAS institucionaliza este ciclo (verificar → detectar no conformidad → corregir → re-verificar → actualizar soporte de prevención) como el mecanismo permanente de mejora continua del SGSI, alineado con la Cláusula 10.1 de ISO/IEC 27001:2022, asegurando que cada hallazgo de auditoría se traduzca en una actualización concreta tanto de los controles técnicos como del material de capacitación del personal.